

PERFIL PROFESIONAL

Declaración profesional

Soy Licenciado en Criminalística y completé el Certificado Profesional de Ciberseguridad de Google, orientando actualmente mi desarrollo profesional hacia el área de ciberseguridad. Si bien no ejercí profesionalmente en Criminalística, mi formación universitaria me permitió desarrollar habilidades transferibles como el pensamiento analítico, la observación, la atención al detalle, el análisis basado en evidencias y el seguimiento de procedimientos.

A través de mi formación en ciberseguridad adquirí conocimientos y práctica en seguridad de redes, análisis de tráfico, detección y respuesta a incidentes, gestión de riesgos, Linux, SQL y Python, además de fundamentos relacionados con herramientas SIEM e IDS. Tengo especial interés en comenzar mi carrera en áreas como Security Operations Center (SOC), análisis de ciberseguridad y seguridad de redes.

Me caracterizo por ser responsable, autodidacta y comprometido con el aprendizaje continuo. Busco mi primera oportunidad profesional en ciberseguridad, donde pueda aplicar y seguir desarrollando mis conocimientos, trabajar de manera metódica frente a incidentes y contribuir a la protección de sistemas, datos y activos digitales de una organización.

PROYECTO 1

DETECCIÓN, TRIAGE Y ESCALAMIENTO DE POSIBLE COMPROMISO DE CUENTA

■ **Rol Simulado:** SOC Analyst L1

■ **Organización Simulada:** Orion Financial Group (Sector Financiero)

■ **Herramientas y Conceptos Aplicados:** SIEM Triage, Correlation Analysis, NIST Incident Response Lifecycle, 5 W Framework, Evidence-Based Analysis, Technical & Stakeholder Communication, Security Playbooks.

Resumen Ejecutivo (Executive Summary)

Durante el turno de operaciones, el sistema SIEM generó una alerta crítica por múltiples intentos fallidos de autenticación seguidos de un inicio de sesión exitoso desde una dirección IP no asociada históricamente al usuario cfernandez. Como Analista SOC L1, realicé el triage inicial, la correlación de eventos, la validación de la actividad posterior (descarga de archivos y acceso a recursos) y estructuré el escalamiento técnico hacia el nivel L2, aplicando principios de protección de datos y comunicación diferenciada (técnica vs. ejecutiva).

Detección y Línea Temporal del Incidente (Timeline Analysis)

■ **Alerta SIEM (10:12):** Múltiples fallos de autenticación seguidos de éxito (cfernandez / IP: 185.220.101.44).

Secuencia reconstruida:

09:54 - 09:58 → 5 intentos fallidos de inicio de sesión.

09:59 → Autenticación **exitosa** desde la misma IP sospechosa.

10:03 - 10:06 → Acceso al almacenamiento corporativo y descarga de clientes_Q3.xlsx y contratos_clientes.zip (archivos dentro de los permisos legítimos del usuario).

10:10 → Intento de acceso al recurso restringido Finance-Shared (**Acceso rechazado** por falta de privilegios).

Análisis Metodológico (Enfoque de las 5 W)

Who (¿Quién?): Cuenta corporativa afectada: cfernandez (Área Comercial). La identidad real del operador de la sesión no pudo validarse inicialmente.

What (¿Qué ocurrió?): Fuerza bruta o uso de credenciales comprometidas seguido de acceso a recursos de red y exfiltración potencial de dos documentos.

When (¿Cuándo?): Mañana de un día laborable (09:54 - 10:12), lo que obligó a profundizar la investigación más allá de la simple hora del evento.

Where (¿Dónde?): Involucró el sistema de autenticación, almacenamiento compartido interno y pasarela de red.

Why (¿Por qué?): Indicadores consistentes con el uso no autorizado de credenciales, buscando acceso a información sensible de clientes.

Triage Inicial: Hechos Confirmados vs. Incertidumbres

Hechos Confirmados:

Secuencia de autenticación fallida + exitosa desde la IP 185.220.101.44.

Descarga legítima por permisos de la cuenta de dos archivos comerciales.

Intento bloqueado al recurso de finanzas.

Aspectos No Determinados (Pendientes de L2):

Vector inicial de robo de credenciales (phishing, infostealer, etc.).

Presencia de malware en el endpoint (no concluyente).

Si los archivos descargados fueron exfiltrados fuera de la red corporativa.

Escalamiento y Comunicaciones Profesionales

A. Comunicación Técnica (Para SOC L2 / Incident Response):

"Se escalan eventos de la cuenta cfernandez tras detectar patrón de fuerza bruta exitoso desde IP externa no asociada al historial (185.220.101.44), dispositivo no reconocido y ausencia de

MFA. La sesión descargó clientes_Q3.xlsx y contratos_clientes.zip. Intento a Finance-Shared denegado. Se solicita análisis de malware en endpoint y verificación de exfiltración de datos."

B. Comunicación No Técnica (Para Stakeholders / Gerencia):

"Hemos detectado actividad inusual en una cuenta corporativa interna. El acceso no autorizado fue contenido rápidamente. Los intrusos accedieron a documentación comercial estándar para la cual la cuenta tenía permisos, pero los sistemas de seguridad bloquearon intentos posteriores en áreas restringidas. No hay evidencia confirmada de salida de información fuera de la empresa y el caso está siendo investigado activamente."

Acciones de Contención Propuestas

- Deshabilitación temporal de la cuenta y revocación de tokens de sesión activos.
- Restablecimiento seguro de credenciales y aplicación obligatoria de MFA.
- Preservación de logs del SIEM y telemetría de EDR para la auditoría posterior.

PROYECTO 2

AUDITORÍA INTERNA DE SEGURIDAD Y CUMPLIMIENTO (BOTIUM TOYS)

■ **Rol Simulado:** IT Security Auditor / Compliance Analyst

■ **Organización Simulada:** Botium Toys (Comercio minorista y en línea)

■ **Herramientas y Conceptos Aplicados:** NIST Cybersecurity Framework (CSF), PCI DSS, GDPR, Security Controls Assessment, Least Privilege, Separation of Duties, Risk Mitigation.

Resumen Ejecutivo

Se realizó una auditoría interna de seguridad sobre la empresa ficticia Botium Toys para evaluar su postura frente a estándares de la industria y normativas internacionales. El análisis determinó un nivel de riesgo alto (8/10), impulsado por la ausencia de cifrado en datos de tarjetas de crédito, falta de controles de acceso basados en privilegios mínimos y deficiencias en el cumplimiento de normativas como PCI DSS y GDPR.

Alcance y Metodología

■ **Alcance:** El programa de seguridad global de la compañía, incluyendo red interna, dispositivos de empleados, servicios de comercio electrónico y almacenamiento de datos.

■ **Metodología:** Evaluación basada en el marco **NIST CSF** y revisión de cumplimiento normativo (PCI DSS, GDPR, SOC 1 y SOC 2).

Hallazgos Clave y Brechas Identificadas

- **Control de Accesos:** Ausencia del principio de *Mínimo Privilegio* y *Separación de Funciones*, lo que otorga a los usuarios permisos superiores a los necesarios.
- **Protección de Datos:** Falta total de cifrado para información de tarjetas de pago (incumplimiento crítico de PCI DSS) y deficiencias en la clasificación e inventario de datos personales (GDPR).
- **Respuesta y Recuperación:** Inexistencia de un Plan de Recuperación ante Desastres (DRP) y ausencia de copias de seguridad automatizadas.
- **Detección:** Falta de un Sistema de Detección de Intrusos (IDS) para monitorear actividades anómalas en la red.

Recomendaciones Prioritarias

- Implementar estrictamente el **Principio de Mínimo Privilegio** y controles de separación de funciones.
- Desplegar cifrado robusto para los datos de tarjetas de crédito y transacciones de clientes en tránsito y reposo.
- Instalar un **IDS** y establecer copias de seguridad periódicas junto con un Plan de Recuperación ante Desastres documentado.

PROYECTO 3

EVALUACIÓN DE RIESGOS Y CONTROLES DE INFRAESTRUCTURA (NOVATECH SOLUTIONS)

- **Rol Simulado:** Junior Risk Analyst / Information Security Evaluator
- **Organización Simulada:** NovaTech Solutions (Empresa PyME híbrida de 35 empleados)
- **Herramientas y Conceptos Aplicados:** NIST SP 800-30 Rev. 1, Risk Assessment, Threat Identification, Vulnerability Prioritization, Asset Management, CIA Triad.

Resumen Ejecutivo

Se ejecutó una evaluación de riesgos cualitativa bajo la metodología **NIST SP 800-30 Rev. 1** sobre la infraestructura tecnológica de NovaTech Solutions. El análisis se centró en identificar vulnerabilidades críticas derivadas del trabajo híbrido, equipos sin cifrado, permisos excesivos y la ausencia de autenticación multifactor (MFA), generando una matriz de priorización de riesgos y un plan de remediación técnica.

Alcance y Metodología

- **Alcance:** Activos tecnológicos, estaciones de trabajo Windows, notebooks corporativas, red Wi-Fi, servidor interno de archivos y cuentas de usuario.

■ **Metodología:** Estimación cualitativa de riesgos calculando la probabilidad y gravedad de los eventos de amenaza sobre la Tríada CIA (Confidencialidad, Integridad y Disponibilidad).

Principales Riesgos Identificados

■ **Equipos Corporativos sin Cifrado (Riesgo Alto):** Notebooks con información local expuestas ante pérdida o robo físico.

■ **Ausencia de MFA y Controles de Acceso Remoto (Riesgo Alto):** Conexiones VPN ausentes o cuentas vulnerables a robo de credenciales.

■ **Gestión de Backups Deficiente (Riesgo Alto):** Respaldos manuales sin periodicidad definida ni pruebas de restauración formales.

■ **Falta de Inventario y Concientización (Riesgo Alto):** Activos no mapeados y carencia de capacitaciones periódicas en seguridad para los empleados.

Estrategia de Mitigación y Remediación

■ Implementar cifrado de disco completo en todas las notebooks y equipos corporativos.

■ Desplegar **MFA** de manera obligatoria en accesos remotos y cuentas con privilegios sensibles.

■ Automatizar las copias de seguridad y realizar pruebas periódicas de recuperación de datos.

■ Formalizar y documentar los procedimientos de altas y bajas (*offboarding*) de personal junto con un inventario de activos actualizado.

PROYECTO 4

ANÁLISIS DE TRÁFICO DE RED E INSPECCIÓN DE PAQUETES (WIRESHARK)

- **Rol Simulado:** Network Security Analyst / Packet Inspector
- **Organización Simulada:** Entorno de Pruebas Corporativo (Simulación de Tráfico Sospechoso)
- **Herramientas y Concepts Aplicados:** Wireshark, Packet Analysis, TCP Handshake, Cleartext Protocols (HTTP/FTP), Anomalies Detection, Network Forensics.

Resumen Ejecutivo

Se realizó una captura e inspección profunda de tráfico de red utilizando **Wireshark** para identificar anomalías de comunicación, validar el estado de los protocolos de transporte y detectar la transmisión de credenciales o datos sensibles en texto claro (plaintext). El análisis permitió aislar sesiones no cifradas y verificar el comportamiento de conexiones sospechosas dentro de la red corporativa.

Alcance y Metodología

- **Alcance:** Tráfico de red capturado en interfaces de red locales simulando segmentos de usuarios y servidores corporativos.
- **Metodología:** Filtros de visualización por protocolos (http, tcp, dns, ftp), análisis del flujo de paquetes (Follow TCP Stream) y validación de cabeceras para identificar anomalías o brechas de confidencialidad.

Hallazgos Principales y Análisis Técnico

- **Hallazgo 1: Uso de Protocolos No Cifrados (HTTP / FTP)**
 - *Descripción:* Se detectó transmisión de credenciales y datos de usuario en texto plano mediante los protocolos HTTP y FTP, exponiendo la información a ataques de interceptación (*man-in-the-middle*).
- **Hallazgo 2: Anomalías en Solicitudes DNS**
 - *Descripción:* Identificación de consultas DNS masivas hacia dominios externos de reputación desconocida, indicando posibles patrones de resolución automatizada o comunicación con servidores de comando y control (C2).
- **Hallazgo 3: Análisis de Conexiones TCP**
 - *Descripción:* Verificación de la correcta apertura y cierre de sesiones (Three-way handshake), detectando tramas con banderas (*flags*) anómalas e intentos de escaneo de puertos internos.

Recomendaciones de Seguridad y Mitigación

- Migrar de manera inmediata todos los servicios web y de transferencia de archivos legados a protocolos seguros (HTTPS, SFTP, FTPS).
- Implementar restricciones y monitoreo activo sobre las consultas DNS salientes mediante firewalls de próxima generación (NGFW).
- Capacitar al personal técnico en el uso de herramientas de análisis forense de redes para la detección temprana de anomalías.

PROYECTO 5

AUTOMATIZACIÓN DE TAREAS DE CIBERSEGURIDAD CON PYTHON

 **Rol Simulado:** Junior Security Automation Developer

Herramientas y Conceptos Aplicados: Python (Algoritmos, Bucles for/while, Funciones, Condicionales, Manejo de Archivos), Scripting para SOC, Gestión de Listas de Bloqueo (Blocklists).

Resumen Ejecutivo

Se desarrolló un script en **Python** para automatizar la actualización y el filtrado de listas de direcciones IP bloqueadas (*block lists*) dentro de la infraestructura corporativa. La solución reduce el tiempo de respuesta operativo al procesar de forma automática archivos de registro (*log files*), eliminando IPs autorizadas y optimizando la gestión de Indicadores de Compromiso (IOCs).

Alcance y Metodología

Alcance: Procesamiento automatizado de listas de control de acceso y archivos de texto plano con registros de conexión.

Metodología: Uso de lógica de programación (apertura de archivos, lectura línea por línea, estructuras condicionales y manipulación de listas) para validar entradas de red contra políticas de seguridad predefinidas.

Componentes Técnicos Desarrollados

Lectura y Manipulación de Archivos: Implementación de funciones para abrir archivos de texto, extraer direcciones IP y convertirlas en estructuras de datos iterables.

Algoritmo de Filtrado y Actualización: Lógica para recorrer una lista de IPs restringidas y remover (*remove*) aquellas que ya no deben estar bloqueadas o que forman parte de excepciones aprobadas.

Automatización del Flujo de Trabajo: Reducción drástica del esfuerzo manual del analista al procesar cientos de registros en segundos.

Beneficios Operativos

Optimización del tiempo de análisis en el SOC mediante la automatización de tareas repetitivas de verificación de IOCs.

Base sólida para escalar hacia integraciones con APIs de seguridad y plataformas de orquestación (SOAR).

PROYECTO 6

AUDITORÍA DE REGISTROS Y ACCESOS MEDIANTE CONSULTAS SQL

Rol Simulado: Security Data Analyst / Database Auditor

Herramientas y Conceptos Aplicados: SQL (Consultas relacionales, Cláusulas SELECT, WHERE, JOIN, Filtrado de logs, Análisis de autenticación).

Resumen Ejecutivo

Se diseñaron y ejecutaron consultas avanzadas en **SQL** sobre bases de datos de control de acceso y autenticación corporativa. El objetivo principal fue auditar los registros de actividad (*logs*), identificar patrones de intentos fallidos de inicio de sesión y analizar los permisos asignados a las cuentas de usuario para prevenir escalamientos de privilegios no autorizados.

Alcance y Metodología

■ **Alcance:** Tablas relacionales de registros de eventos de login, perfiles de usuario y asignación de roles de acceso.

■ **Metodología:** Aplicación de comandos de consulta estructurados (SELECT, filtrado condicional por fechas y horas, uso de operadores lógicos y uniones de tablas) para extraer anomalías de seguridad directamente de las bases de datos.

Hallazgos y Consultas Clave

■ Detección de Intentos Fallidos de Autenticación:

■ *Descripción:* Creación de consultas orientadas a aislar registros con múltiples fallos de contraseña concentrados en franjas horarias no laborales, facilitando la detección temprana de ataques de fuerza bruta.

■ Auditoría de Privilegios de Usuario:

■ *Descripción:* Uso de cruces de tablas (*JOINS*) para mapear qué usuarios poseían roles administrativos activos frente a los que requerían privilegios estándar (aplicación del principio de menor privilegio).

■ Análisis de Conexiones por Dirección IP:

■ *Descripción:* Filtrado de tablas de transacciones para rastrear el origen geográfico o de red de las sesiones iniciadas en los sistemas críticos.

Valor para la Organización

■ Capacidad técnica comprobada para extraer y analizar grandes volúmenes de datos de seguridad directamente desde bases de datos corporativas.

■ Mejora en la trazabilidad de incidentes a través de consultas rápidas y precisas sobre los registros históricos de auditoría.